Network Analysis – Malware Compromise

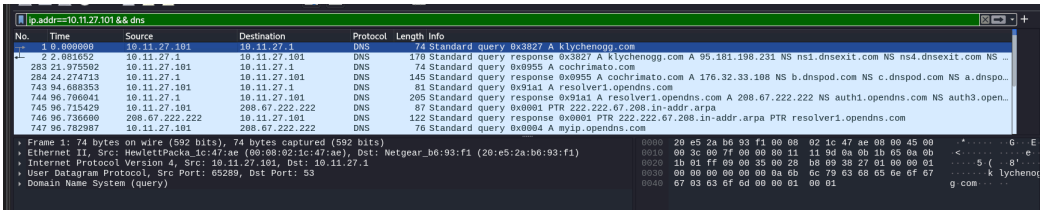
1. Kịch bản

- SOC xem xét cảnh báo của SIEM và phát hiện cảnh báo về kết nối đến domain độc hại đã biết. Lưu lượng đến từ máy Sara - kế toán nhận lượng lớn email từ khách hàng mỗi ngày. Xem email gateway log từ hộp thư Sara, không có gì đáng ngờ từ email khách hàng. Sara cho biết 1 khách hàng gửi cho cô ấy 1 hóa đơn chứa tài liệu có macro, cô ấy mở mail và chương trình crash. SOC cần phân tích tệp PCAP chứa lưu lượng

2. Write-up

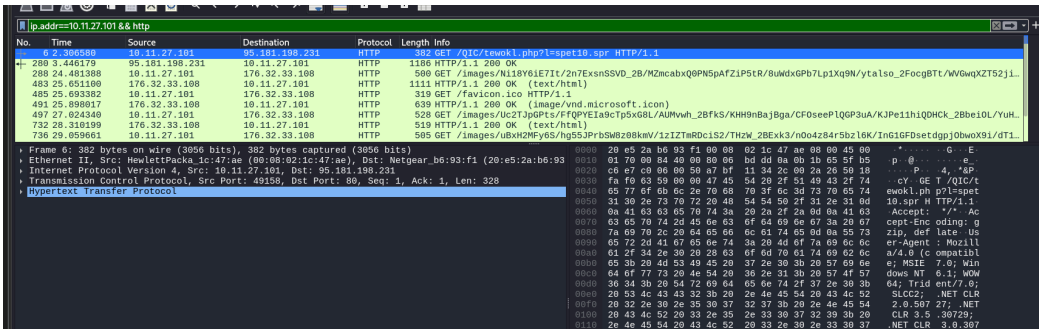
1. What's the private IP of the infected host?

- Host có IP 10.11.27.101 gửi truy vấn DNS tới rất nhiều tên miền đáng ngờ

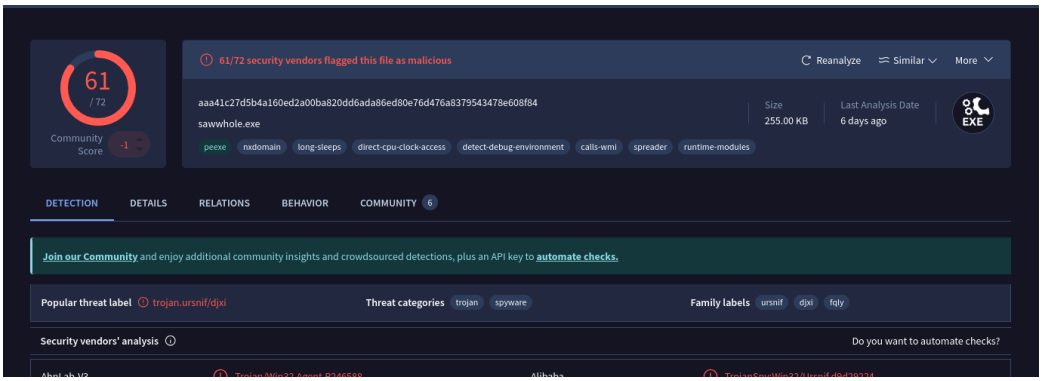


2. What's the malware binary that the macro document is trying to retrieve?

- Sử dụng bộ lọc ip.addr==10.11.27.101 && http để lấy các lưu lượng từ máy bị xâm nhập khởi tạo HTTP GET để tải file malware



- /QIC/tewokl.php?l=spet10.spr → macro ép client gửi HTTP GET đến attacker để tải payload
- Lấy file về và kiểm tra trên virustotal → xác nhận đây là malware



3. From what domain HTTP requests with GET /images/ are coming from?

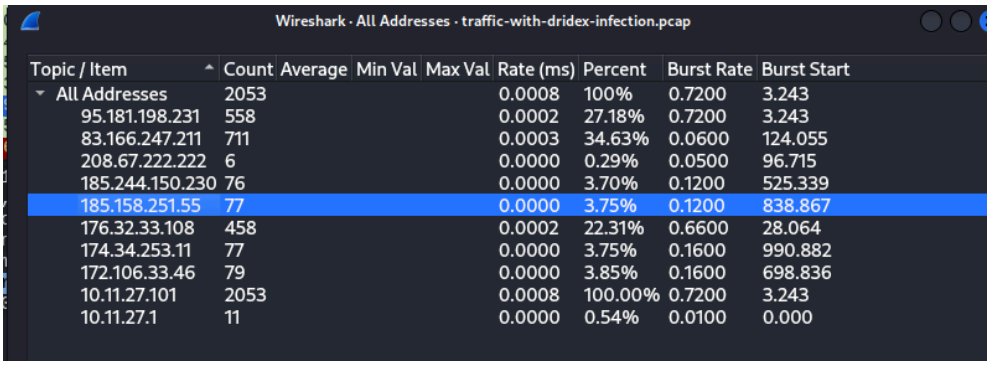
- Xem truy vấn HTTP ở header host sẽ cho biết tên domain gửi request

4. The SOC Team found Dridex, a follow-up malware from Ursnif infection, to be the culprit. The customer who sent her the macro file is compromised. What's the full URL ending in .rar where Ursnif retrieves the follow-up malware from?

- Malware mà web shell tải về được là con trojan họ ursnif. Con trojan này tiếp tục tải thêm 1 file độc hại về máy

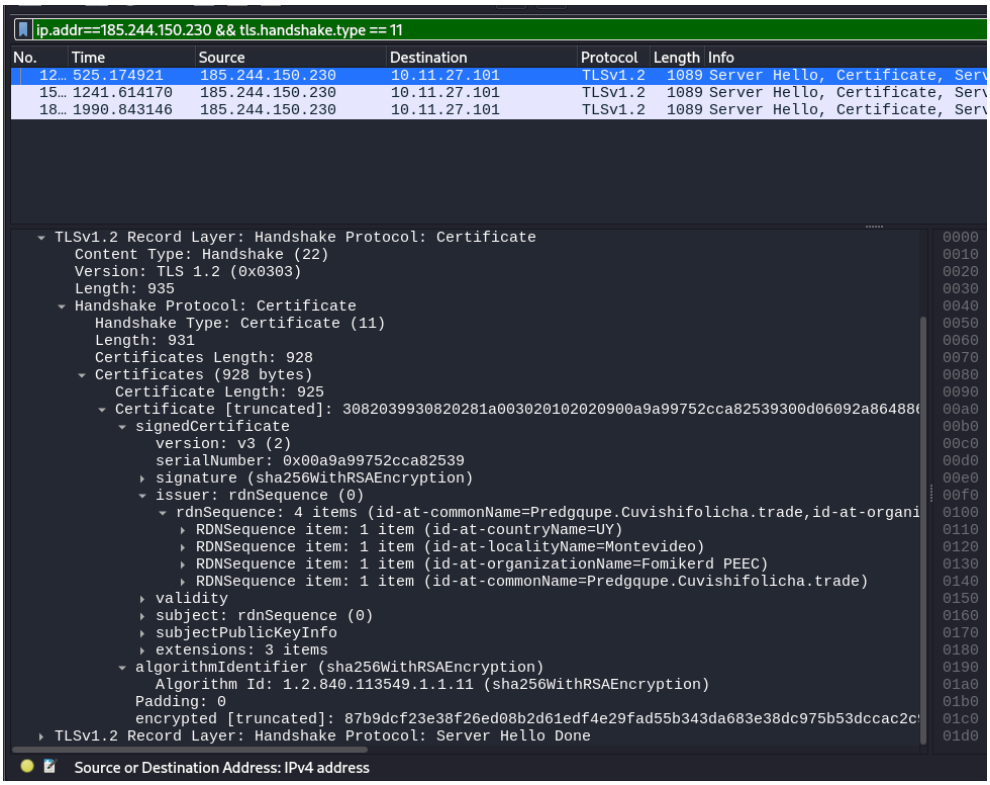
5. What is the Dridex post-infection traffic IP addresses beginning with 185.?

- Dridex:
  - Malware thiết kế để đánh cắp thông tin đăng nhập ngân hàng của user.
  - Thu thập data nhạy cảm, cung cấp và thực thi module độc hại
- Đặc điểm phát hiện Dridex
  - Có countryName và localityName hợp lệ
  - Các trường khác chứa chuỗi ngẫu nhiên
  - Sử dụng bộ lọc: tls.handshake.type == 11
- Trong danh sách có 2 IP bắt đầu bằng 185 → kiểm tra 2 IP này

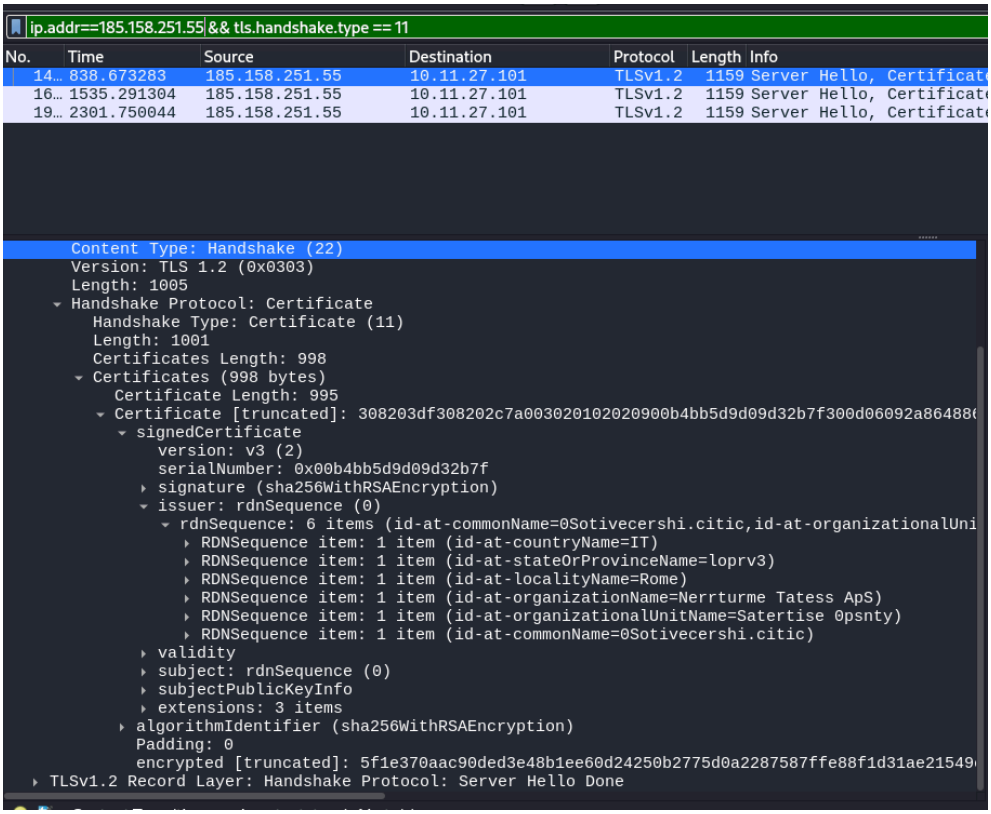


Topic / Item	Count	Average	Min Val	Max Val	Rate (ms)	Percent	Burst Rate	Burst Start
All Addresses	2053				0.0008	100%	0.7200	3.243
95.181.198.231	558				0.0002	27.18%	0.7200	3.243
83.166.247.211	711				0.0003	34.63%	0.0600	124.055
208.67.222.222	6				0.0000	0.29%	0.0500	96.715
185.244.150.230	76				0.0000	3.70%	0.1200	525.339
185.158.251.55	77				0.0000	3.75%	0.1200	838.867
176.32.33.108	458				0.0002	22.31%	0.6600	28.064
174.34.253.11	77				0.0000	3.75%	0.1600	990.882
172.106.33.46	79				0.0000	3.85%	0.1600	698.836
10.11.27.101	2053				0.0008	100.00%	0.7200	3.243
10.11.27.1	11				0.0000	0.54%	0.0100	0.000

- IP 185.244.150.230 thỏa mãn điều kiện



- IP 185.158.251.55 có các trường đều hợp lệ



3. Kết luận

- Máy nạn nhân bị lừa chạy 1 file macro - đoạn mã tự động hóa nhúng trong tài liệu
- Macro khởi chạy và ép Client tạo HTTP GET request để tải payload từ máy attacker. Payload này là 1 loại trojan Ursnif
- Trojan này kết nối đến C2 có IP là 95.181.198.231 để tải malware Dridex - malware nhắm vào thông tin đăng nhập ngân hàng
- Sau khi tải về, nó sử dụng IP 185.244.150.230 (phía C2 server) để giao tiếp với nạn nhân qua giao thức TLS